Atak i zabezpieczenie sieci

Temat projektu: Atak brute-force na usługę SSH.

- **Autorzy:**
  - Amelia Skoczylas,
  - Zuzanna Lech.

Spis treści:

1. Wstęp
    1.1 Cel i zakres projektu
    1.2 Charakterystyka protokołu SSH
    1.3 Definicja i mechanizm ataku brute-force
2. Opis środowiska laboratoryjnego
    2.1 Topologia sieci
    2.2 Charakterystyka węzłów (Atakujący vs Ofiara)
    2.3 Wykorzystane narzędzia i oprogramowanie
3. Realizacja ataku
    3.1 Rekonesans i skanowanie portów (Nmap)
    3.2 Przygotowanie słowników i parametrów ataku
    3.3 Przeprowadzenie ataku brute-force (Hydra)
    3.4 Analiza logów systemowych na maszynie ofiary
    3.5 Weryfikacja dostępu
4. Wdrożenie mechanizmów obronnych
    4.1 Konfiguracja Fail2Ban
    4.2 Utwardzanie konfiguracji serwera SSH (sshd_config)
    4.3 Implementacja uwierzytelniania opartego na kluczach
5. Weryfikacja skuteczności zabezpieczeń
    5.1 Ponowna próba ataku po wdrożeniu blokad
    5.2 Porównanie wyników przed i po zabezpieczeniu
6. Podsumowanie i wnioski
7. Bibliografia

1. Wstęp

1.1. Cel i zakres projektu

Głównym celem projektu jest kompleksowa analiza bezpieczeństwa protokołu zdalnej administracji SSH (Secure Shell) w kontekście zagrożeń płynących z ataków typu *brute-force*. Praca ma na celu nie tylko teoretyczne omówienie mechanizmów ataku, ale przede wszystkim praktyczna demonstracja wektora zagrożenia w kontrolowanym środowisku laboratoryjnym oraz wdrożenie wielowarstwowych mechanizmów obronnych (mitygacji).

W ramach realizacji projektu określono następujący zakres prac:

- **Identyfikacja luk bezpieczeństwa:** Analiza podatności usługi SSH wynikających z błędów konfiguracyjnych oraz stosowania poświadczeń o niskiej entropii (słabych haseł).
- **Ofensywa (Faza ataku):** Przeprowadzenie symulacji zautomatyzowanego ataku słownikowego przy użyciu dedykowanych narzędzi klasy *password cracker*.
- **Analiza poincydentalna:** Szczegółowy przegląd logów systemowych pod kątem identyfikacji śladów i anomalii świadczących o próbie nieautoryzowanego dostępu.
- **Defensywa (Faza zabezpieczenia):** Wdrożenie prewencyjnych mechanizmów ochrony (systemów klasy IPS) oraz proces utwardzania (*hardeningu*) konfiguracji serwera, zakończone ostateczną weryfikacją ich skuteczności.

1.2. Charakterystyka protokołu SSH

Protokół SSH (Secure Shell) stanowi obecnie fundament bezpiecznego zarządzania infrastrukturą sieciową i serwerową. Został on wprowadzony jako bezpieczna alternatywa dla przestarzałych protokołów komunikacyjnych (takich jak Telnet czy rlogin), oferując silne szyfrowanie przesyłanych danych. Gwarantuje to wysoką poufność oraz integralność transmisji, chroniąc ruch sieciowy przed podsłuchem (*sniffingiem*).

Pomimo że SSH sam w sobie oferuje wysoki poziom bezpieczeństwa transmisji (szyfrowanie asymetryczne, tunelowanie), najsłabszym ogniwem całego mechanizmu pozostaje czynnik ludzki - a dokładnie proces uwierzytelniania oparty na tradycyjnych hasłach. Ze względu na powszechność wykorzystania domyślnego portu 22/TCP, usługa ta jest permanentnie narażona na zautomatyzowane próby siłowego przełamania zabezpieczeń, co czyni ją jednym z głównych celów dla botnetów oraz systemów skanujących w sieci globalnej.

1.3. Definicja i mechanizm ataku brute-force

Atak siłowy (*brute-force*) to zautomatyzowana metoda krypto analityczna, której celem jest odgadnięcie poświadczeń dostępowych poprzez systematyczne sprawdzanie wszystkich możliwych kombinacji znaków. Ze względu na ogromne ograniczenia czasowe w przypadku złożonych haseł, w warunkach sieciowych zagrożenie to ewoluowało i najczęściej przybiera zoptymalizowaną formę - tzw. **ataku słownikowego** (*Dictionary Attack*).

Cecha	Czysty atak Brute-Force	Atak słownikowy
Metoda działania	Sprawdza absolutnie każdą kombinację znaków (np. `aaaa`, `aaab`, `aaac`...).	Sprawdza wyłącznie gotowe słowa/hasła z pliku (np. `admin`, `haslo123`, `test`).
Czas trwania	Bardzo długi (często matematycznie niemożliwy do wykonania w sensownym czasie dla haseł pow. 10 znaków).	Znacznie krótszy (narzędzie testuje tylko najbardziej prawdopodobne opcje).
Skuteczność	Gwarantowana sukcesem (w teorii, dysponując nieskończonym czasem).	Wysoka przeciwko hasłom wymyślanym przez ludzi, ale zerowa przeciwko hasłom losowym (np. `X#9pQ!2z`).

Kluczowe aspekty mechanizmu ataku:

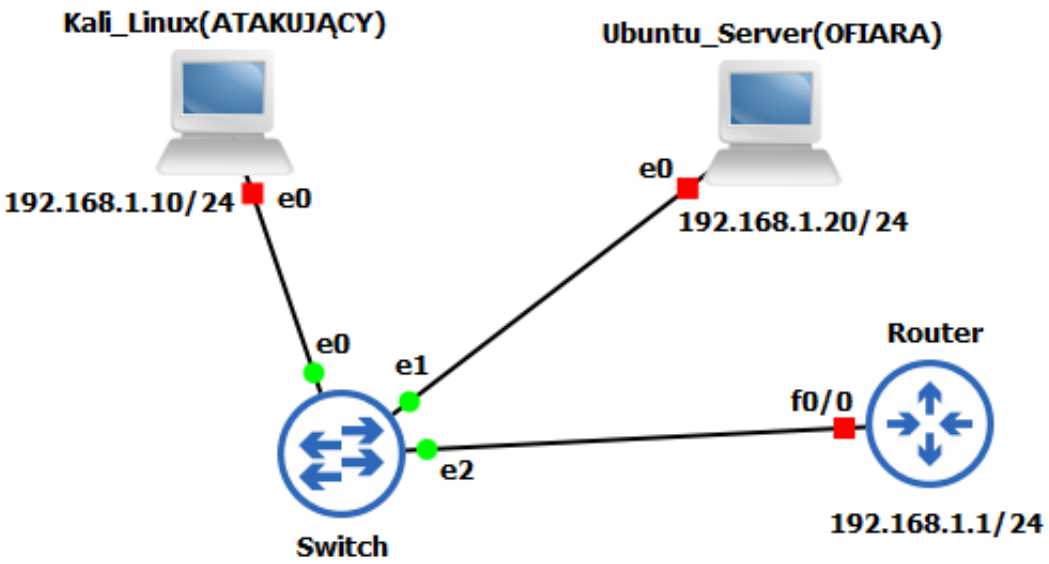
- **Automatyzacja i szybkość:** Atakujący wykorzystują specjalistyczne oprogramowanie zdolne do generowania tysięcy żądań logowania na minutę. Opierają się przy tym na obszernych bazach danych (słownikach), zawierających miliony haseł pochodzących z wcześniejszych wycieków informacji.
- **Eksploatacja błędów ludzkich:** Skuteczność ataku słownikowego opiera się na statystycznym prawdopodobieństwie. Użytkownicy często wykazują tendencję do tworzenia haseł łatwych do zapamiętania - opartych na popularnych wyrazach, imionach czy datach urodzenia - co drastycznie zawęża pulę kombinacji niezbędnych do sprawdzenia. Ponadto, ataki te z wysoką skutecznością wymierzone są w domyślne hasła systemowe i fabryczne, które w wyniku zaniedbań administratorów nie zostały zmienione po początkowej instalacji oprogramowania lub urządzeń.
- **Wykrywalność:** Charakterystyczną cechą tego ataku jest generowanie znacznego ruchu sieciowego oraz pozostawianie licznych śladów w logach systemowych (powtarzające się odrzucone próby logowania). Pozwala to na relatywnie sprawną identyfikację intruza przy użyciu odpowiednio skonfigurowanych systemów monitorujących.

2. Opis środowiska laboratoryjnego

2.1. Topologia sieci

Środowisko laboratoryjne oparto na modelu hybrydowym, łączącym emulację sprzętu sieciowego (GNS3) z wirtualizacją systemów operacyjnych. Topologia składa się z segmentu dostępowego, w którym operuje stacja atakująca, oraz segmentu serwerowego, gdzie znajduje się ofiara.

- **Środowisko emulacyjne (GNS3):** Wykorzystane do zamodelowania infrastruktury sieciowej, konfiguracji routerów (działających na realnych obrazach systemu Cisco IOS) oraz wdrożenia zabezpieczeń sprzętowych (np. `login block-for`).
- **Integracja z hipernadzorcą (Oracle VirtualBox):** Wykorzystana do uruchomienia rzeczywistych systemów operacyjnych (Kali Linux oraz Ubuntu Server) wewnątrz topologii GNS3. Pozwala to na przeprowadzenie autentycznej komunikacji sieciowej. Całość pracuje w całkowicie izolowanej wirtualnej sieci, co eliminuje ryzyko wycieku ruchu brute-force do sieci zewnętrznych (produkcyjnych).



Rysunek 1. Topologia sieciowa zaimplementowana w środowisku GNS3.

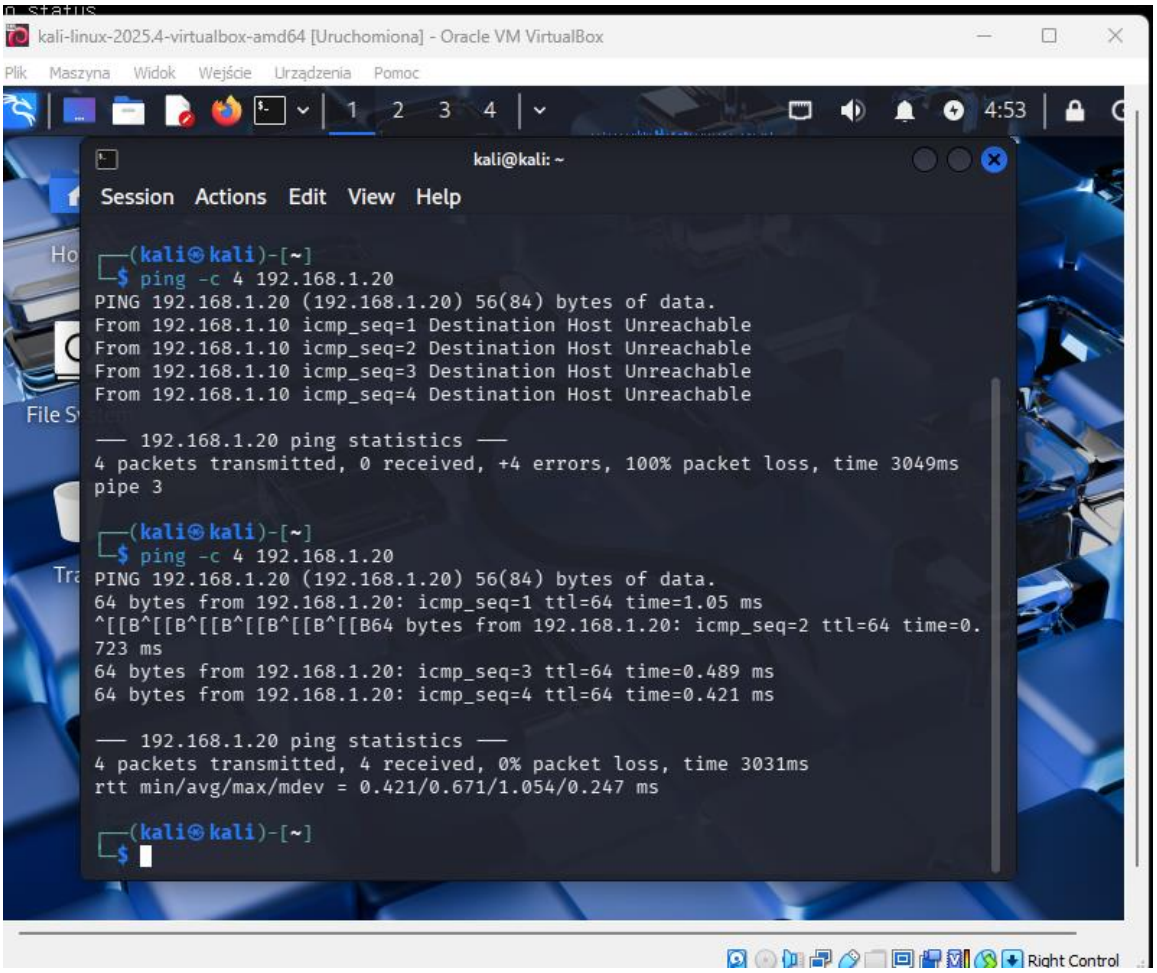
Urządzenia potrzebne do wykonania topologii

- **1 × Ethernet Switch** (zwykły switch wbudowany w GNS3),
- **1 × Router Cisco** (3725),
- **2 × PC** (wirtualne hosty VPCS: jeden pełni rolę zwykłego użytkownika/ofiary, a drugi atakującego).

Tabela 2. Plan adresacji i konfiguracja interfejsów

Urządzenie	Interfejs	Adres IP	Maska	Brama	Rola
Kali_Linux	e0	192.168.1.10	/24	192.168.1.1	Atakujący
Ubuntu_Server	e0	192.168.1.20	/24	192.168.1.1	Ofiara (serwer SSH)
Brama (Router)	Fa0/0	192.168.1.1	/24	------	Brama domyślna

W celu potwierdzenia poprawności wdrożonej topologii oraz routingu, przeprowadzono test łączności za pomocą protokołu ICMP, który zakończył się sukcesem.



Rysunek 2. Weryfikacja poprawności konfiguracji – udany test łączności (ping) pomiędzy stacją atakującą a serwerem ofiary.

2.2. Charakterystyka węzłów (Atakujący vs Ofiara)

W projekcie wykorzystano dwa profile systemowe, symulujące role atakującego i ofiary:

Cecha	Atakujący (Kali_Linux)	Ofiara (Ubuntu_Server)
System Operacyjny	Dystrybucja Kali Linux wyposażona w natywne narzędzia audytowe i ofensywne.	Dystrybucja Ubuntu Server z uruchomionym demonem OpenSSH.
Konfiguracja wyjściowa	Adres IP: `192.168.1.10`, Interfejs: `eth0`.	Adres IP: `192.168.1.20`, Port: 22/TCP, Uwierzytelnianie hasłem (brak limitów).
Zadanie w projekcie	Przeprowadzenie rekonesansu, identyfikacja wersji usługi oraz wykonanie ataku słownikowego.	Przechowywanie zasobów, rejestracja prób włamań w logach oraz implementacja mechanizmów utwardzających (hardening).
Konto testowe	Wykorzystanie narzędzia Hydra i słownika `rockyou.txt`.	Utworzone konto `tester` z przypisanym słabym, słownikowym hasłem w celu symulacji błędu ludzkiego.

2.3. Wykorzystane narzędzia i oprogramowanie

Do realizacji założonych celów wykorzystano zestaw profesjonalnych narzędzi, które podzielono na kategorie funkcjonalne:

Narzędzia Rekonesansu:

- **Nmap:** Skaner sieciowy użyty do wykrywania aktywnych hostów oraz precyzyjnego określenia wersji protokołu SSH działającego na porcie 22.

Narzędzia Ofensywne:

- **Hydra:** Elastyczne narzędzie do przeprowadzania ataków brute-force na protokoły sieciowe. Pozwala na jednoczesne testowanie wielu par login-hasło.

Narzędzia Diagnostyczne i Analizy:

- **Wireshark:** Analizator pakietów użyty do przechwytywania ruchu. Pozwala na obserwację negocjacji protokołu SSH oraz nagłego wzrostu liczby pakietów TCP podczas ataku.
- **Słownik RockYou.txt:** Standardowa baza haseł pochodzących z wycieków, na której oparto skuteczność ataku słownikowego.

Technologie Zabezpieczające:

- **Cisco IOS (login block-for):** Mechanizm sprzętowy blokujący dostęp po określonej liczbie nieudanych prób (odpowiednik IPS uruchamiany bezpośrednio na routerze).

- **OpenSSH (Klucze RSA):** Implementacja kryptografii asymetrycznej jako docelowa, najbezpieczniejsza metoda ochrony uwierzytelniania.
- **Fail2Ban:** Oprogramowanie typu IPS (*Intrusion Prevention System*) dla systemów Linux, monitorujące logi systemowe i dynamicznie modyfikujące reguły zapory sieciowej (firewalla) w celu blokowania adresów IP generujących zbyt wiele błędnych prób logowania.

3. Realizacja ataku (Etap "ATAK")

W tej części sprawozdania przedstawiono przebieg działań ofensywnych, których celem było uzyskanie nieautoryzowanego dostępu do serwera Ubuntu poprzez przełamanie zabezpieczeń usługi SSH.

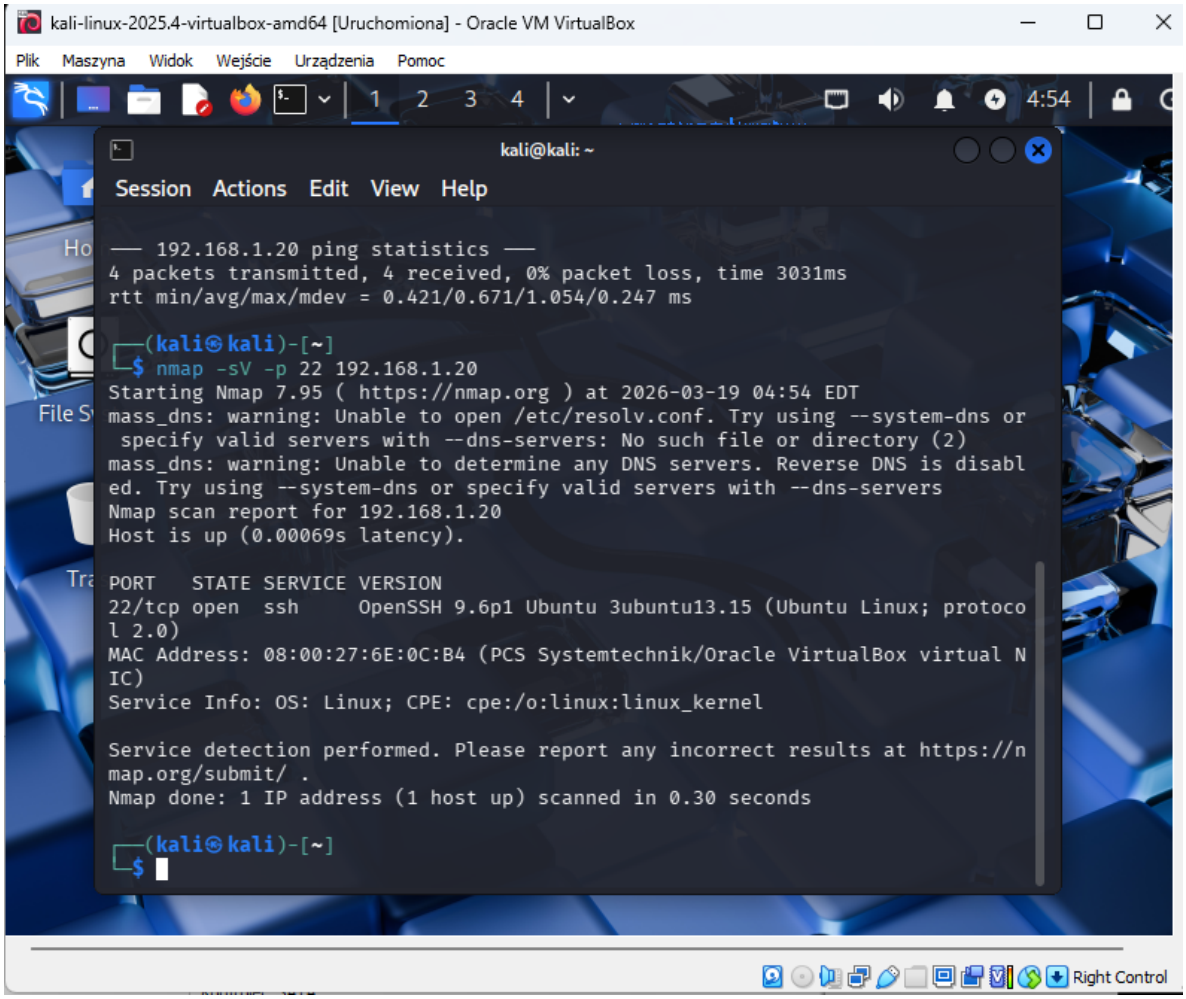
3.1. Rekonesans i skanowanie portów (Nmap)

Pierwszym krokiem ataku była identyfikacja aktywnych usług na hoście ofiary (`192.168.1.20`). Wykorzystano narzędzie **Nmap** z flagą analizy wersji usług. Wykorzystanie flagi -sV umożliwia weryfikację stanu portu oraz precyzyjne określenie wersji oprogramowania (fingerprinting). Informacja o wersji OpenSSH 9.6p1 pozwala atakującemu na poszukiwanie dedykowanych exploitów w bazach takich jak Exploit-DB, choć w tym przypadku skupiono się na słabych poświadczeniach.

Wykonana komenda:

Bash
```
nmap -sV -p 22 192.168.1.20
```

- `-sV`: Wykrywanie wersji uruchomionych usług.
- `-p 22`: Ograniczenie skanowania do portu SSH w celu zachowania dyskrecji.



Rysunek 3. Wynik skanowania portu 22 na maszynie ofiary za pomocą narzędzia Nmap.

Wynik skanowania: Nmap zidentyfikował otwarty port `22/tcp` z uruchomioną usługą OpenSSH `9.6p1 (Ubuntu Linux)`. Potwierdzenie dostępności standardowego portu SSH pozwoliło na przejście do kolejnej fazy.

3.2. Przygotowanie słowników i parametrów ataku

Do przeprowadzenia ataku typu *dictionary attack* przygotowano dwa pliki tekstowe:

1. **user.txt:** Zawierający listę popularnych nazw użytkowników (np. `root`, `admin`, `user`, `tester`).
2. **rockyou.txt:** Standardowy słownik haseł systemowych.

Zdecydowano się na atak na konkretnego użytkownika `tester`, o którym uzyskano informacje w fazie rekonesansu (np. poprzez analizę metadanych lub wcześniejsze skanowanie).

Parametr	Wartość	Opis
Cel	192.168.1.20	Adres IP serwera ofiary
Użytkownik	tester	Wybrany login do ataku
Słownik haseł	rockyou.txt	Baza 14 mln haseł z wycieków
Liczba wątków	4	Balans między szybkością a stabilnością
Protokół	SSH	Usługa docelowa

Słownik rockyou.txt, będący standardem w testach penetracyjnych, został uprzednio rozpakowany poleceniem `gzip -d`. Użycie konkretnego loginu 'tester' znacząco skraca czas ataku w porównaniu do jednoczesnego zgadywania loginów i haseł.

3.3. Przeprowadzenie ataku brute-force (Hydra)

Głównym narzędziem ataku było **THC Hydra**. Narzędzie to charakteryzuje się wysoką wydajnością dzięki możliwości nawiązywania wielu równoległych połączeń (wątków).

Wykonana komenda:

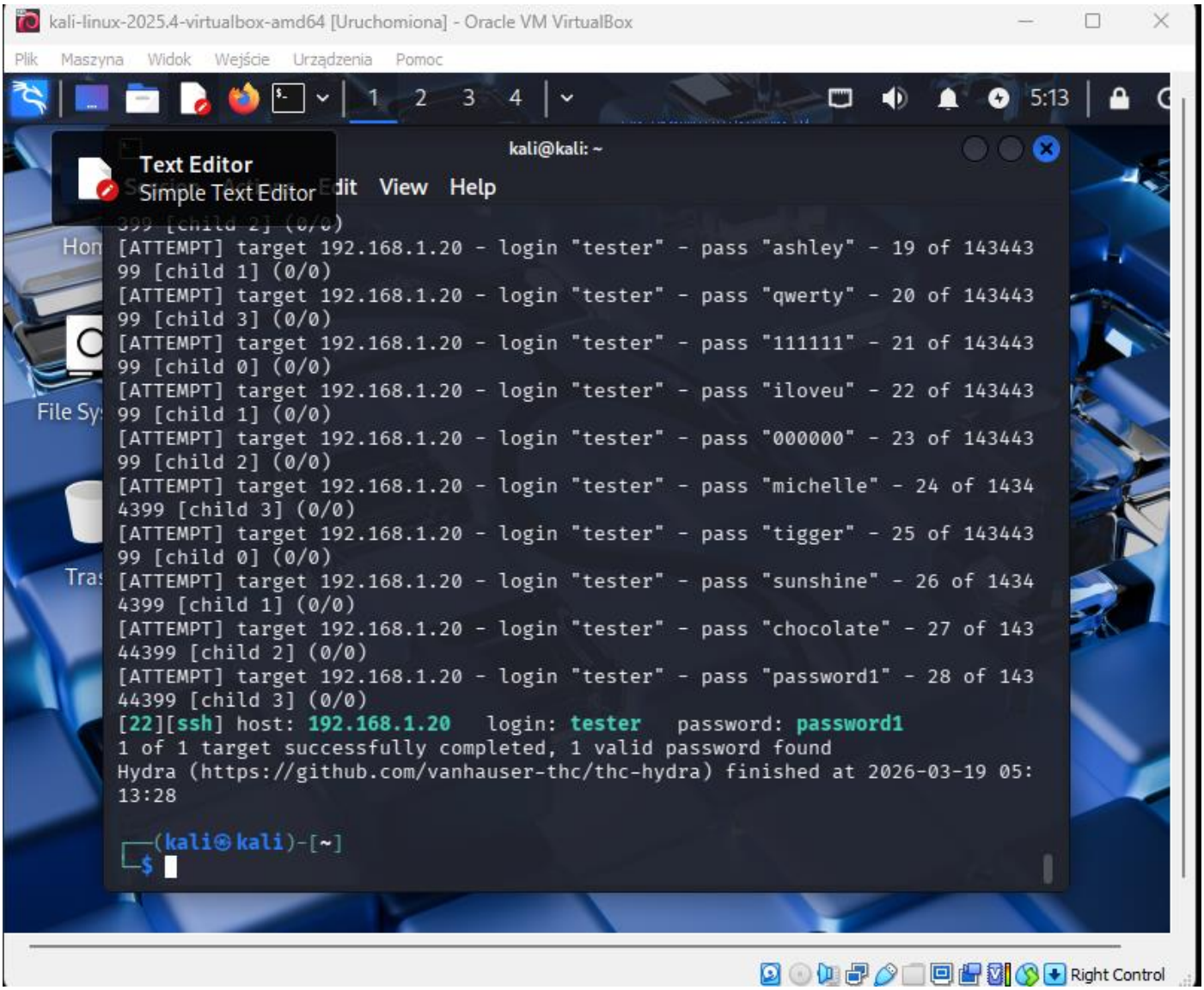
Bash
```
hydra -l tester -P /usr/share/wordlists/rockyou.txt 192.168.1.20 ssh -t 4 -V
```

Opis przełączników:

- `-l tester`: Określenie konkretnego loginu użytkownika.
- `-P [...]`: Ścieżka do słownika haseł.
- `192.168.1.20 ssh`: Adres IP celu oraz nazwa atakowanego protokołu.
- `-t 4`: Liczba równoległych wątków (ograniczona do 4, aby uniknąć przeciążenia usługi i błędów połączenia).

- -V: Tryb *verbose* (wyświetlanie każdej próby logowania w czasie rzeczywistym).

Podczas pracy narzędzia w trybie Verbose (-V) zaobserwowano, że serwer nie nakłada żadnych opóźnień (delay) między kolejnymi próbami. Poprawne hasło znaleziono już w 28. próbie, w ciągu kilku sekund, co potwierdza brak jakichkolwiek mechanizmów typu Rate Limiting w domyślnej konfiguracji usługi.



Rysunek 4. Sukces ataku brute-force – narzędzie Hydra odnajduje poprawne hasło dla użytkownika tester.

3.4. Analiza logów systemowych na maszynie ofiary

W celu zrozumienia, jak atak jest widoczny z perspektywy administratora, przeanalizowano logi systemowe na serwerze Ubuntu.

Komenda podglądu logów:

Bash

```
tail -n 20 /var/log/auth.log
```

```
tester@ubuntuserver:~$ sudo tail -n 20 /var/log/auth.log
[sudo] password for tester:
2026-03-19T09:13:24.103161+00:00 ubuntuserver sshd[1750]: Failed password for tester from 192.168.1.10 port 45324 ssh2
2026-03-19T09:13:24.166156+00:00 ubuntuserver sshd[1752]: Failed password for tester from 192.168.1.10 port 45344 ssh2
2026-03-19T09:13:24.166544+00:00 ubuntuserver sshd[1751]: Failed password for tester from 192.168.1.10 port 45330 ssh2
2026-03-19T09:13:25.844312+00:00 ubuntuserver sshd[1750]: Accepted password for tester from 192.168.1.10 port 45324 ssh2
2026-03-19T09:13:25.845327+00:00 ubuntuserver sshd[1750]: pam_unix(sshd:session): session opened for user tester(uid=1000) by tester(uid=0)
2026-03-19T09:13:25.847040+00:00 ubuntuserver systemd-logind[879]: New session 5 of user tester.
2026-03-19T09:13:26.021622+00:00 ubuntuserver sshd[1750]: pam_unix(sshd:session): session closed for user tester
2026-03-19T09:13:26.023334+00:00 ubuntuserver systemd-logind[879]: Session 5 logged out. Waiting for processes to exit.
2026-03-19T09:13:26.024023+00:00 ubuntuserver systemd-logind[879]: Removed session 5.
2026-03-19T09:13:28.232419+00:00 ubuntuserver sshd[1751]: Failed password for tester from 192.168.1.10 port 45330 ssh2
2026-03-19T09:13:28.232733+00:00 ubuntuserver sshd[1753]: Failed password for tester from 192.168.1.10 port 45350 ssh2
2026-03-19T09:13:28.232881+00:00 ubuntuserver sshd[1752]: Failed password for tester from 192.168.1.10 port 45344 ssh2
2026-03-19T09:13:29.388618+00:00 ubuntuserver sshd[1752]: Connection closed by authenticating user tester 192.168.1.10 port 45344 [preauth]
2026-03-19T09:13:29.388713+00:00 ubuntuserver sshd[1752]: PAM 1 more authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.10  user=teste
r
2026-03-19T09:13:29.391149+00:00 ubuntuserver sshd[1753]: Connection closed by authenticating user tester 192.168.1.10 port 45350 [preauth]
2026-03-19T09:13:29.391195+00:00 ubuntuserver sshd[1753]: PAM 1 more authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.10  user=teste
r
2026-03-19T09:13:29.391912+00:00 ubuntuserver sshd[1751]: Connection closed by authenticating user tester 192.168.1.10 port 45330 [preauth]
2026-03-19T09:13:29.391945+00:00 ubuntuserver sshd[1751]: PAM 1 more authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.10  user=teste
r

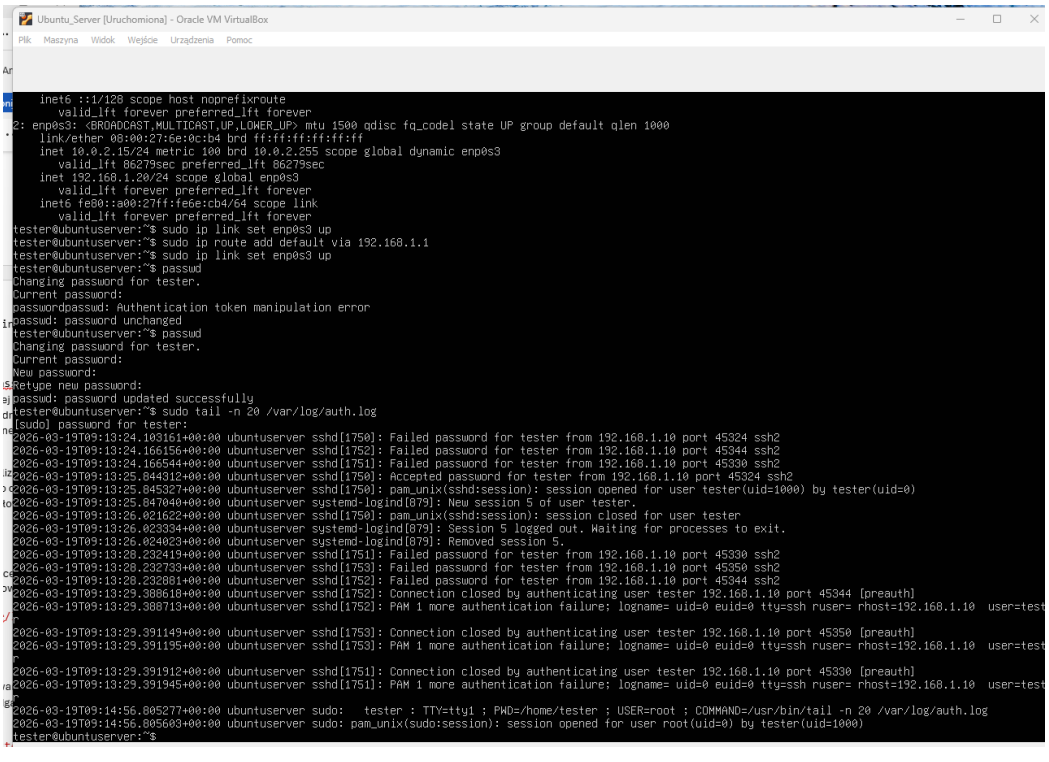
2026-03-19T09:14:56.805277+00:00 ubuntuserver sudo:   tester : TTY=tty1 ; PWD=/home/tester ; USER=root ; COMMAND=/usr/bin/tail -n 20 /var/log/auth.log
2026-03-19T09:14:56.805603+00:00 ubuntuserver sudo: pam_unix(sudo:session): session opened for user root(uid=0) by tester(uid=1000)
tester@ubuntuserver:~$
```

Rysunek 5. Fragment logów systemowych serwera (auth.log) rejestrujący intensywny atak słownikowy z adresu IP atakującego (192.168.1.10).

Obserwacje: W pliku `auth.log` zarejestrowano kilkanaście wpisów o treści `Failed password for tester from 192.168.1.10 port [X] ssh2`. Każda linijka odpowiadała jednej próbie podjętej przez narzędzie Hydra. Gwałtowny przyrost tych wpisów (kilka na sekundę) jest jednoznacznym dowodem na trwający atak typu brute-force. Brak jakichkolwiek blokad w domyślnej konfiguracji pozwolił atakującemu na kontynuowanie prób aż do skutku.

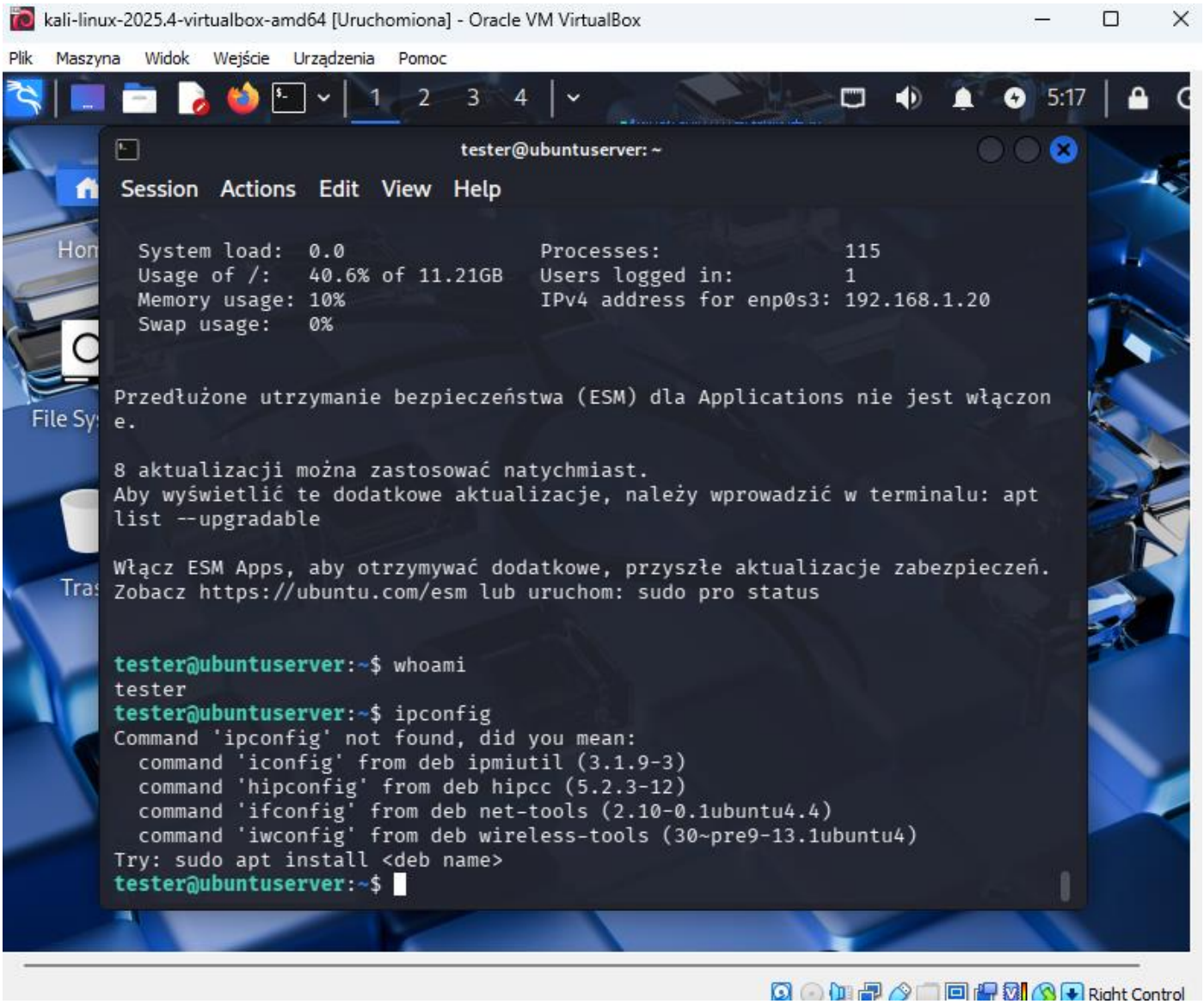
Logi systemowe są kluczowym elementem w procesie Incident Response. W analizowanym przypadku wpisy 'Failed password' pojawiały się niemal natychmiastowo jeden po drugim. Dla administratora jest to jednoznaczny sygnał, że proces nie jest inicjowany przez człowieka, lecz przez zautomatyzowany skrypt (botnet/tool)."

Podsumowanie etapu: Atak zakończył się pełnym sukcesem. Dzięki słabej polityce haseł i braku mechanizmów IPS (takich jak Fail2Ban), intruz uzyskał dostęp do powłoki systemowej serwera.



3.5 Weryfikacja dostępu

Po uzyskaniu hasła przez Hydrę, przeprowadzono próbę autoryzowanego zalogowania się z poziomu stacji Kali Linux. Po wpisaniu komendy `ssh tester@192.168.1.20` i podaniu odgadniętego hasła, uzyskano dostęp do powłoki (shell) serwera z uprawnieniami użytkownika tester.



Rysunek 6. Potwierdzenie uzyskania nieautoryzowanego dostępu do serwera Ubuntu poprzez protokół SSH.

4. Wdrożenie mechanizmów obronnych

Po udanej demonstracji ataku w Rozdziale 3, podjęto działania mające na celu zabezpieczenie serwera Ubuntu przed ponownymi próbami siłowego przełamania poświadczeń. Zastosowano podejście wielowarstwowe (*defense in depth*), łącząc narzędzia reagujące w czasie rzeczywistym z poprawą konfiguracji samej usługi.

4.1. Konfiguracja Fail2Ban

Fail2Ban to system zapobiegania włamaniom (IPS), który monitoruje logi systemowe w poszukiwaniu wzorców świadczących o ataku (np. wielokrotne błędy logowania z jednego adresu IP) i automatycznie modyfikuje reguły firewalla, aby zablokować intruza.

Proces wdrożenia:

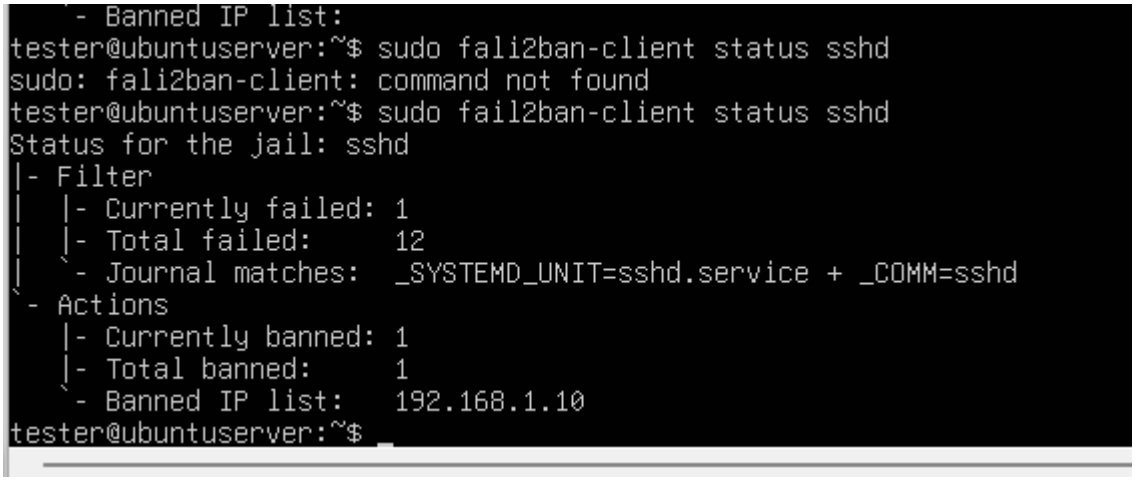
1. **Instalacja:** Narzędzie zainstalowano komendą `sudo apt install fail2ban`.
2. **Konfiguracja lokalna:** Zamiast edytować plik główny, utworzono plik `jail.local`, aby zachować czystość konfiguracji: `sudo cp /etc/fail2ban/jail.conf /etc/fail2ban/jail.local`.
3. **Definicja parametrów ochrony:** W sekcji `[sshd]` ustawiono następujące restrykcje:
    a. `enabled = true` - aktywacja ochrony dla SSH.
    b. `maxretry = 3` - blokada następuje już po 3 nieudanych próbach (zamiast domyślnych 5).
    c. `bantime = 10m` - tymczasowa blokada na 10 minut.
    d. `findtime = 5m` - okno czasowe, w którym liczone są próby.

Parametr	Wartość pomyślna	Wartość wdrożona	Opis i uzasadnienie
maxretry	5	3	Zmniejszenie progu tolerancji na błędy, co przyspiesza reakcję na atak.
bantime	10m	10m / 1h	Czas trwania blokady na poziomie firewalla (iptables/nftables).
findtime	10m	5m	Okres, w którym zliczane są nieudane próby logowania.
backend	auto	systemd / polling	Metoda monitorowania logów przez Fail2Ban.

Schemat działania Fail2Ban

`Atakujący (SSH)` -> `Logi /var/log/auth.log` -> `Filtr Fail2Ban` -> `Akcja (Ban w Firewallu)` -> `Blokada ruchu`.

Po zidentyfikowaniu intruza, Fail2Ban komunikuje się bezpośrednio z systemową zaporą ogniową (iptables). Tworzona jest dedykowana reguła odrzucająca (REJECT/DROP) wszystkie pakiety przychodzące z adresu IP 192.168.1.10. Dzięki temu serwer SSH przestaje być obciążany procesami autoryzacji, co chroni go również przed atakami typu DoS (Denial of Service) wynikającymi z nadmiernego obciążenia procesora przez próby logowania.



Rysunek 7. Konfiguracja reguł blokowania w usłudze Fail2Ban.

4.2. Utwardzanie konfiguracji serwera SSH (sshd_config)

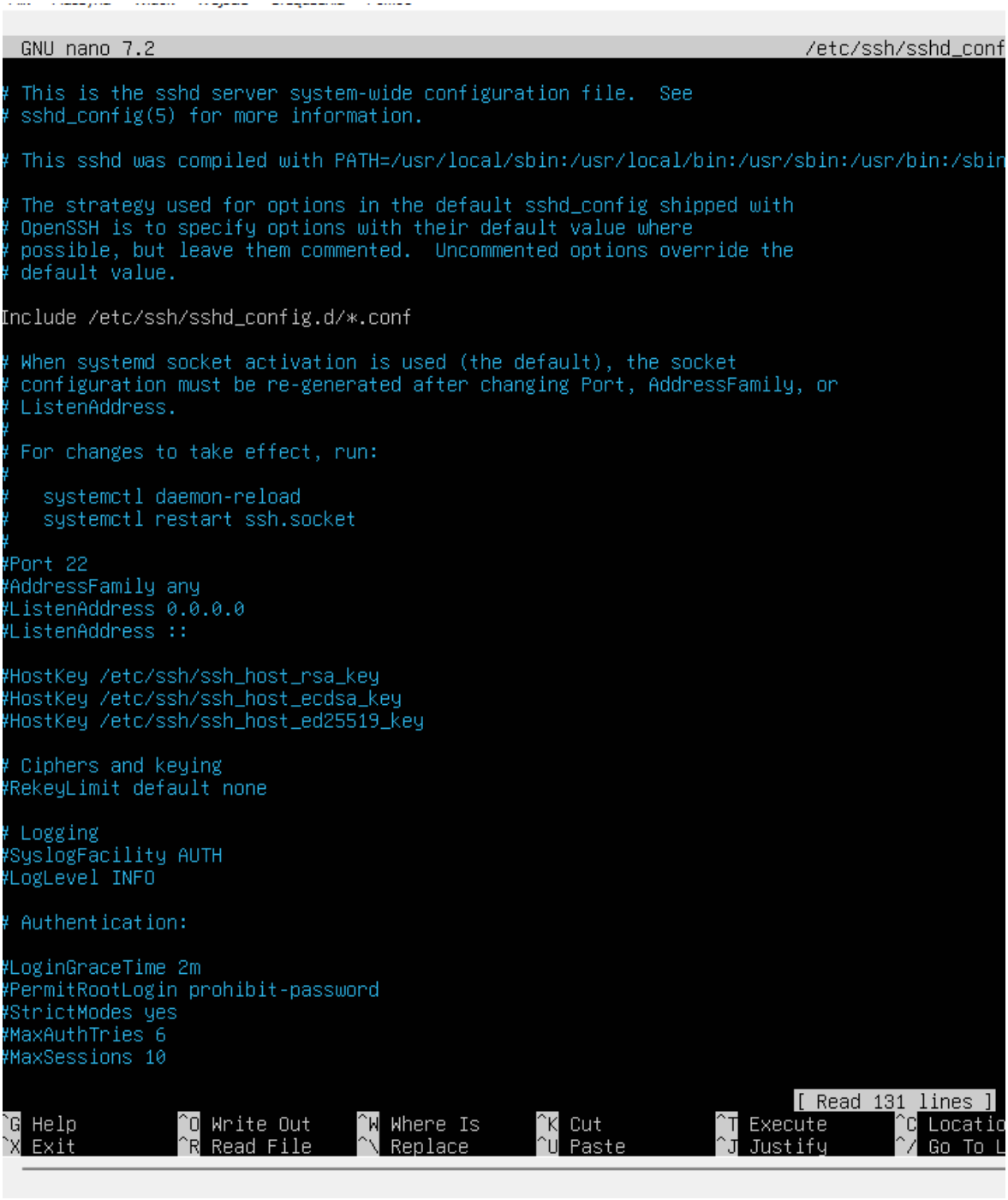
Sam protokół SSH posiada wbudowane opcje, które znacząco podnoszą poziom bezpieczeństwa, jeśli zostaną odpowiednio skonfigurowane w pliku `/etc/ssh/sshd_config`.

Wprowadzone zmiany:

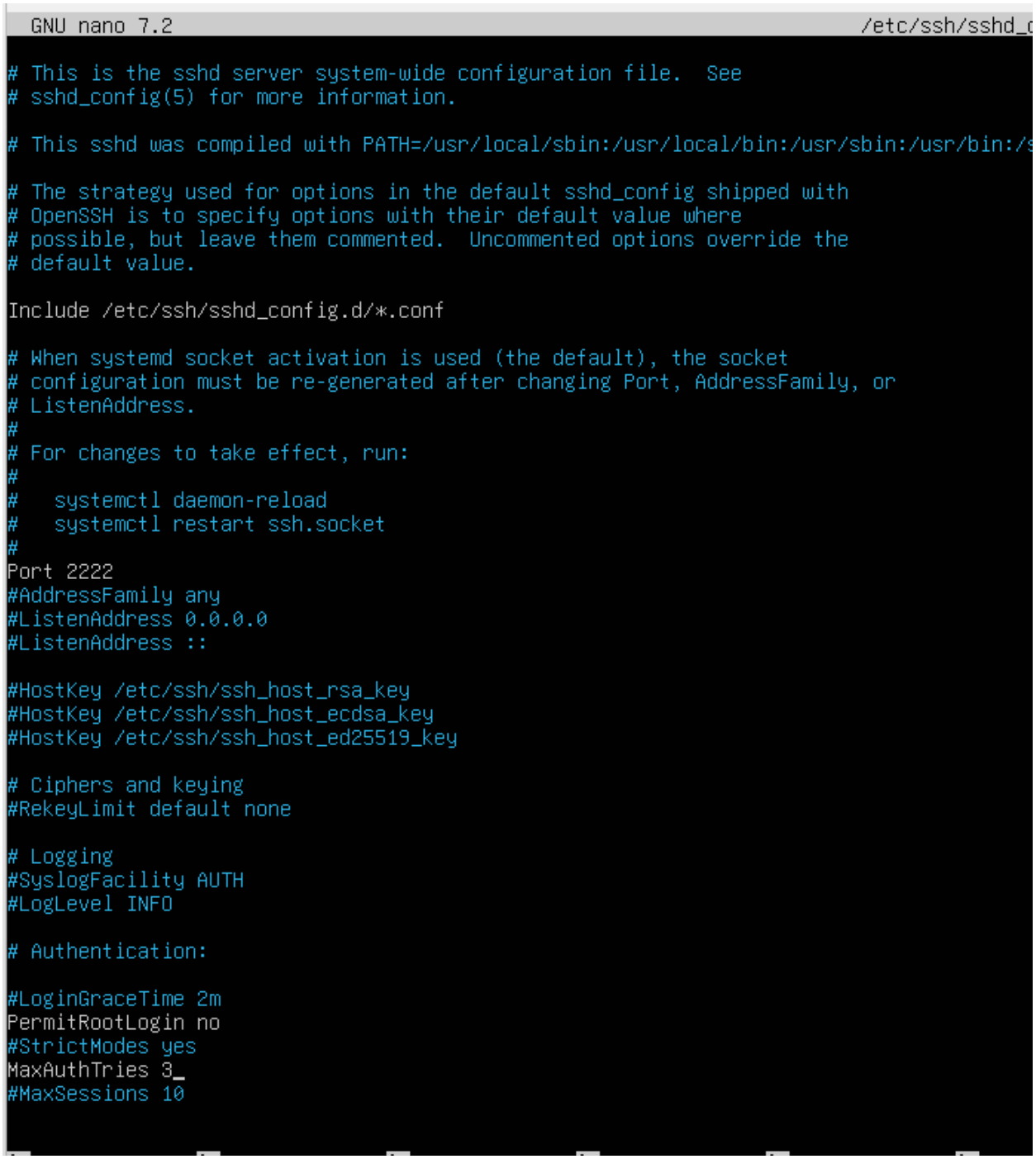
- **Zmiana domyślnego portu:** Zmieniono port z 22 na niestandardowy (np. 2222). Pozwala to na uniknięcie większości zautomatyzowanych skanerów internetowych, które atakują tylko port domyślny. Przeniesienie usługi na port 2222 drastycznie zmniejsza liczbę wpisów w logach generowanych przez internetowe boty, które w 99% przypadków skanują tylko port 22. Choć nie jest to zabezpieczenie ostateczne (skanery portów jak Nmap nadal wykryją usługę), to skutecznie eliminuje ono 'szum' i ułatwia analizę logów pod kątem realnych ataków celowanych.
- **Ograniczenie logowania dla roota:** Ustawienie `PermitRootLogin no` uniemożliwia bezpośredni atak na konto administratora o najwyższych uprawnieniach. Konto root jest celem priorytetowym dla każdego atakującego. Wyłączenie możliwości bezpośredniego logowania na to konto wymusza na napastniku odgadnięcie loginu zwykłego użytkownika (np. 'tester'), a następnie przeprowadzenie eskalacji uprawnień, co stanowi dodatkową, trudną do pokonania barierę.
- **Limit prób logowania:** Parametr `MaxAuthTries 3` wymusza rozłączenie sesji po 3 błędnych hasłach na poziomie protokołu.
- **Dostosowanie Fail2Ban:** po zmianie portu usługi w sekcji `[sshd]` pliku `jail.local` należy ustawić także `port = 2222`, ponieważ domyślnie blokada obejmuje tylko port 22.

Tabela podsumowująca zmiany w sshd_config

Parametr	Wartość domyślna	Nowa wartość	Cel zabezpieczenia
Port	22	2222	Ograniczenie zautomatyzowanego skanowania.
PermitRootLogin	prohibit-password	no	Blokada bezpośredniego dostępu do konta root.
MaxAuthTries	6	3	Szybsze zerwanie połączenia przy próbie brute-force.



Rysunek 8a. Domyślna i niezabezpieczona konfiguracja pliku `sshd_config` (widoczny port 22 oraz domyślne PermitRootLogin prohibit-password).



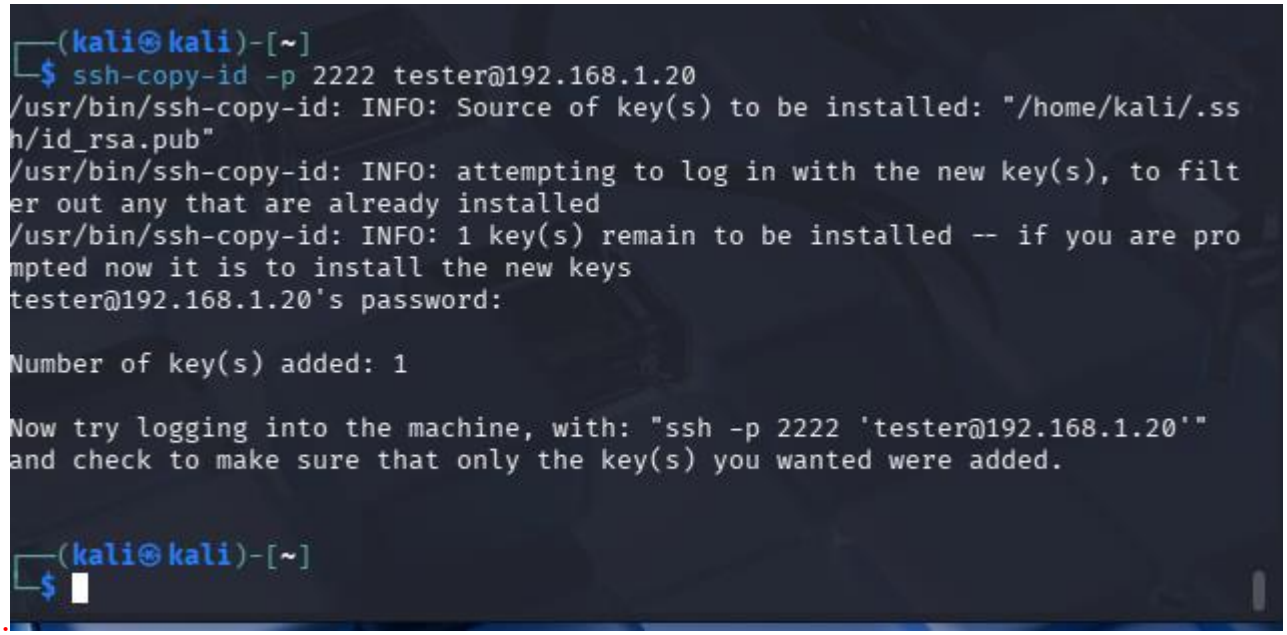
Rysunek 8b. Zmodyfikowana konfiguracja usługi SSH po procesie utwardzania - wdrożenie portu 2222, blokada konta root oraz ograniczenie limitu prób uwierzytelniania.

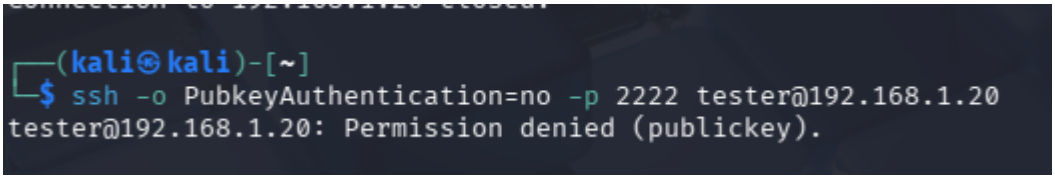
4.3. Implementacja uwierzytelniania opartego na kluczach

Najskuteczniejszą metodą obrony przed atakiem typu *brute-force* jest całkowita rezygnacja z uwierzytelniania hasłem na rzecz kluczy kryptograficznych (RSA/ Ed25519). Atak słownikowy staje się wówczas matematycznie niemożliwy do wykonania. W takim modelu, nawet jeśli atakujący odgadnie hasło, nie zostanie wpuszczony do systemu bez posiadania odpowiedniego klucza prywatnego.

Kroki implementacji:

1. **Generowanie kluczy na stacji klienckiej:** Na maszynie, która ma mieć dostęp, wykonano komendę `ssh-keygen -t rsa -b 4096`.
2. **Transfer klucza publicznego:** Wykorzystano polecenie `ssh-copy-id tester@192.168.1.20`.
3. **Całkowite wyłączenie haseł:** W pliku `sshd_config` zmieniono parametr `PasswordAuthentication` na no.





Rysunek 9. Serwer po przejściu na autoryzację wyłącznie za pomocą kluczy asymetrycznych.

5. Weryfikacja skuteczności zabezpieczeń

W niniejszym rozdziale przeprowadzono testy sprawdzające odporność systemu na ataki po wdrożeniu mechanizmów obronnych. Celem było potwierdzenie, że kombinacja narzędzia Fail2Ban,

zmiany parametrów usługi oraz uwierzytelniania kluczami RSA skutecznie uniemożliwia przejęcie kontroli nad serwerem.

5.1. Ponowna próba ataku po wdrożeniu blokad

Podjęto próbę powtórzenia ataku słownikowego przy użyciu narzędzia Hydra, uwzględniając wprowadzone zmiany w infrastrukturze (nowy port usługi).

Scenariusz testowy:

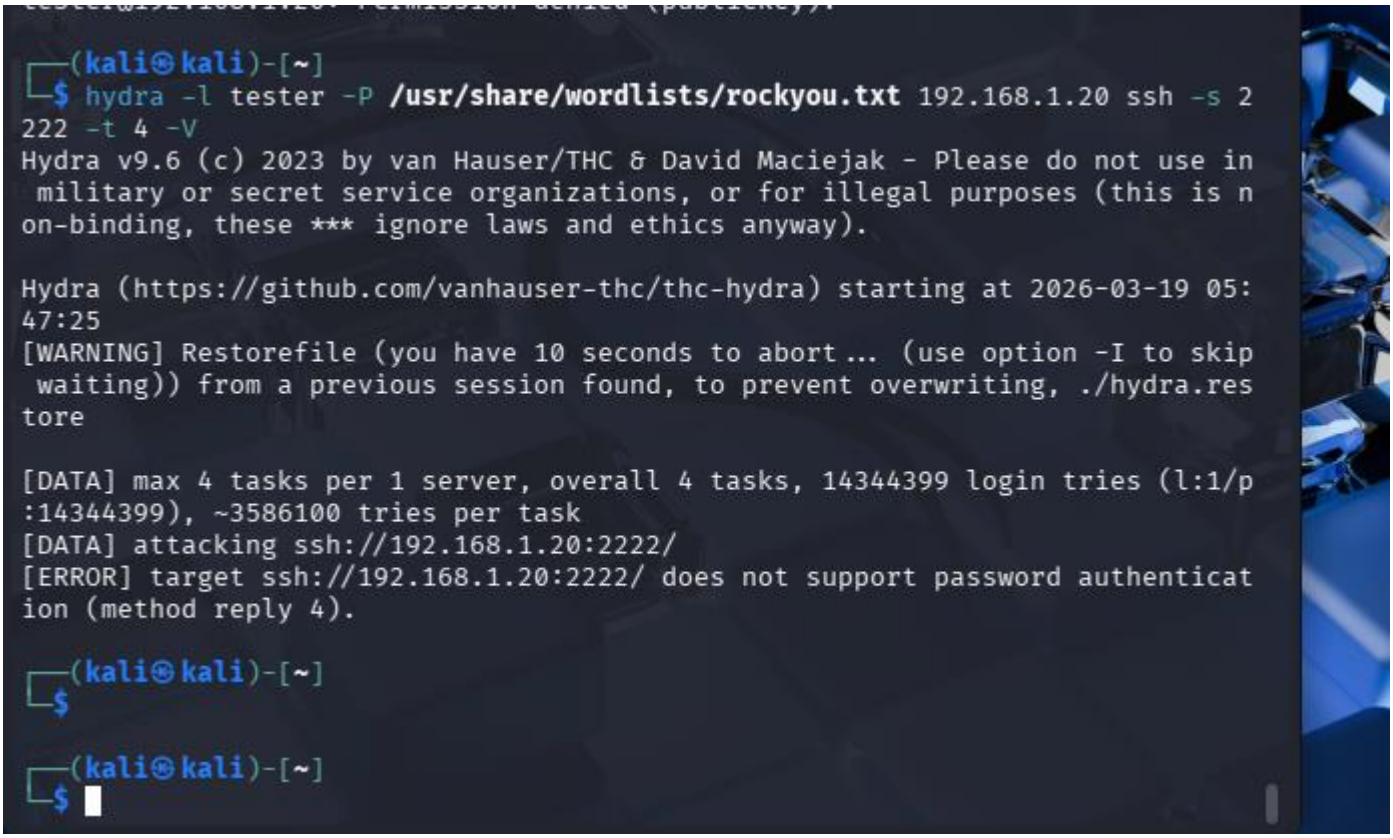
1. **Skanowanie portów:** Uruchomiono skanowanie `nmap -p 22,2222 192.168.1.20`. Skaner wykazał, że port 22 jest zamknięty, natomiast usługa SSH nasłuchuje na porcie 2222.
2. **Uruchomienie Hydry:** Wykonano komendę:

```
hydra -l tester -P /usr/share/wordlists/rockyou.txt 192.168.1.20 ssh -s 2222 -t 4 -V
```

3. **Reakcja systemu (Fail2Ban):** Moduł sshd zliczył nieudane próby logowania z adresu 192.168.1.10 i zablokował go w zaporze sieciowej (rys. 7). Blokadę ponowiono też ręcznie poleceniem `fail2ban-client set sshd banip`, co potwierdza rys. 11.

Obserwacje:

Po wyłączeniu uwierzytelniania hasłem (rozdz. 4.3) Hydra nie rozpoczęła ataku, ponieważ serwer nie obsługuje już metody hasłowej. Narzędzie zakończyło działanie błędem „does not support password authentication” (rys. 10).



Rysunek 10. Przerwanie ataku słownikowego – serwer nie obsługuje już uwierzytelniania hasłem (komunikat Hydry po wyłączeniu haseł).



Rysunek 11. Potwierdzenie aktywnej blokady adresu IP napastnika w statystykach modułu sshd narzędzia Fail2Ban.

5.2. Porównanie wyników przed i po zabezpieczeniu

Zestawienie kluczowych parametrów bezpieczeństwa systemu przed i po utwardzeniu (hardeningu) przedstawia poniższa tabela.

Cecha / Parametr	Stan przed zabezpieczeniem	Stan po zabezpieczeniu	Skutek dla bezpieczeństwa
Port SSH	22 (domyślny)	2222 (niestandardowy)	Eliminacja 99% automatycznych botów skanujących sieć.
Logowanie hasłem	Włączone (podatne)	Wyłączone	Atak słownikowy staje się technicznie niemożliwy.
Limit prób (IPS)	Brak (nieskończoność)	3 próby / Ban 10m	Aktywne blokowanie narzędzi typu Hydra/Medusa.
Dostęp roota	Tylko kluczem	Zablokowany	Ochrona najważniejszego konta w systemie.
Uwierzytelnianie	Wiedza (hasło)	Posiadanie (klucz RSA)	Znacznie wyższy poziom trudności dla napastnika.

Wnioski z weryfikacji:

Wdrożone zabezpieczenia działają komplementarnie. Nawet w przypadku, gdyby atakujący odkrył nowy port usługi (2222), nie jest w stanie przeprowadzić ataku słownikowego z powodu natychmiastowej blokady Fail2Ban. Dodatkowo, całkowita dezaktywacja uwierzytelniania hasłem sprawia, że znajomość ciągu znaków `password1` jest bezużyteczna bez posiadania fizycznego pliku klucza prywatnego. **System można uznać za odporny na wektor ataku typu brute-force.**

6. Podsumowanie i wnioski

Projekt umożliwił praktyczną analizę ataku na usługę SSH, obejmującą fazy rekonesansu, eksploatacji, a także wdrożenie i weryfikację skuteczności mechanizmów obronnych. Analiza ataku brute-force na usługę SSH dostarczyła kluczowych wniosków w obszarze bezpieczeństwa systemów Linux oraz urządzeń sieciowych.

Główne wnioski z projektu:

1. **Krytyczna rola polityki haseł:** Przeprowadzony w rozdziale 3 atak udowodnił, że nawet najlepiej zaprojektowane protokoły (jak SSH) stają się bezużyteczne w obliczu słabych, słownikowych poświadczeń. Wykorzystanie narzędzia Hydra pozwoliło na przejęcie kontroli nad systemem w czasie liczonym w sekundach, co pokazuje, jak skuteczne są zautomatyzowane ataki słownikowe.
2. **Skuteczność strategii "Defense in Depth":** Projekt wykazał, że najsilniejszą ochronę daje połączenie różnych metod zabezpieczeń. Fail2Ban zareagował na dynamikę ataku (warstwa behawioralna), zmiana portu ograniczyła automatyczne skanowanie (warstwa informacyjna), a klucze RSA całkowicie wyeliminowały podatność na zgadywanie haseł (warstwa kryptograficzna).
3. **Wartość analizy logów:** Systematyczne monitorowanie pliku `auth.log` okazało się niezbędne do identyfikacji incydentu. Zrozumienie wzorców pozostawianych przez narzędzia hakerskie jest fundamentem pracy każdego administratora systemów i specjalisty SOC (*Security Operations Center*).
4. **Security through Obscurity jako dodatek:** Zmiana portu z 22 na 2222 potwierdziła swoją wartość jako metoda redukcji „szumu" sieciowego. Choć nie chroni przed zdeterminowanym napastnikiem, pozwala administratorowi skupić się na analizie realnych zagrożeń, zamiast tysięcy prób logowania wykonywanych przez proste boty internetowe.
5. **Przewaga kluczy asymetrycznych:** Faza weryfikacji jednoznacznie wskazała, że przejście na uwierzytelnianie oparte na kluczach publicznych (RSA 4096 bit) całkowicie unieszkodliwia narzędzia typu brute-force/dictionary attack. Jest to obecnie najbardziej rekomendowana metoda zabezpieczania zdalnego dostępu.

Wdrożone w środowisku GNS3 laboratorium pozwoliło na symulację rzeczywistego wektora ataku. Główny cel projektu - zabezpieczenie usługi SSH przed nieautoryzowanym dostępem - został **osiągnięty.** Wnioski płynące z pracy wskazują, że świadoma konfiguracja usług systemowych oraz stosowanie narzędzi wspomagających (IPS) pozwala na zbudowanie wysokiego poziomu odporności systemu, nawet przy zachowaniu pełnej funkcjonalności zdalnego zarządzania.

7. Bibliografia

1. RFC 4251: The Secure Shell (SSH) Protocol Architecture, IETF, 2006. https://www.rfc-editor.org/rfc/rfc4251
2. OpenBSD Project: sshd_config(5), OpenSSH daemon configuration file. https://man.openbsd.org/sshd_config
3. OpenSSH, oficjalna strona i dokumentacja projektu. https://www.openssh.com
4. Fail2Ban, oficjalne repozytorium i dokumentacja projektu. https://github.com/fail2ban/fail2ban
5. THC-Hydra, repozytorium projektu. https://github.com/vanhauser-thc/thc-hydra
6. Nmap Reference Guide. https://nmap.org/book/man.html
7. Wireshark User's Guide. https://www.wireshark.org/docs/wsug_html_chunked/
8. GNS3 Documentation. https://docs.gns3.com
9. Kali Linux Documentation. https://www.kali.org/docs/
10. Ubuntu Server documentation. https://ubuntu.com/server/docs
11. OWASP: Brute Force Attack. https://owasp.org/www-community/attacks/Brute_force_attack
12. Exploit Database. https://www.exploit-db.com